ISO/IEC 27001

Information Security Management System — Governance, Risk, Controls, and Implementation Template

Joao Luiz D'Andrea

Table of contents

1 Executive Summary **3**

2 Overview **4**
- 2.1 Purpose . . . 4
- 2.2 Objectives . . . 4
- 2.3 Scope . . . 4
  - 2.3.1 In scope . . . 4
  - 2.3.2 Out of scope . . . 4
- 2.4 Intended Audience . . . 5

3 Standard Foundation **5**
- 3.1 Background . . . 5
- 3.2 ISMS Principles . . . 5
- 3.3 Core Components . . . 5
- 3.4 Relationship to ISO/IEC 27002 and Annex A . . . 6
  - 3.4.1 Example standards table . . . 6

4 Governance Model **6**
- 4.1 Governance Objectives . . . 6
- 4.2 Governance Structure . . . 7
  - 4.2.1 Example governance bodies . . . 7
- 4.3 Three Lines Model . . . 7
  - 4.3.1 First line . . . 7
  - 4.3.2 Second line . . . 7
  - 4.3.3 Third line . . . 8

5 Roles and Responsibilities **8**
- 5.1 Key Roles . . . 8

5.2 RACI Matrix 8

6 Policy Framework **10**
6.1 Core Policies 10
6.2 Standards and Procedures 10

7 Core Processes **11**
7.1 Context and Scope Management 11
7.2 Risk Assessment 11
7.3 Risk Treatment 11
7.4 Statement of Applicability 11
7.5 Operational Control Management 12
7.6 Incident Management 12
7.7 Performance Evaluation and Improvement 12

8 Control Framework **13**
8.1 Control Domains 13
8.1.1 Example control domains 13
8.2 Sample Control Catalogue 13

9 Artefacts and Evidence **14**
9.1 Required Artefacts 14
9.2 Evidence Model 15

10 Architecture and Technology Implications **15**
10.1 Security by Design 15
10.2 Technology Landscape View 15
10.3 Asset and Dependency Mapping 16

11 Risk Management **16**
11.1 Information Security Risk Model 16
11.2 Example Risk Categories 16
11.3 Risk Register Template 16

12 Metrics and Reporting **17**
12.1 Key Metrics 17
12.2 Dashboard Structure 17

13 Audit and Assurance **17**
13.1 Assurance Model 17
13.2 Testing Themes 18

14 Implementation Roadmap **18**
14.1 Maturity Phases . . . 18
14.1.1 Phase 1: Foundation . . . 18
14.1.2 Phase 2: Control Design . . . 18
14.1.3 Phase 3: Integration . . . 19
14.1.4 Phase 4: Optimisation . . . 19
14.2 Roadmap Table . . . 19

15 Cross-Framework Integration **19**
15.1 Relationship to Other Frameworks . . . 19
15.2 Example Mapping Themes . . . 20

16 Maturity Model **20**
16.1 Suggested Maturity Levels . . . 20
16.1.1 Level 1: Initial . . . 20
16.1.2 Level 2: Repeatable . . . 20
16.1.3 Level 3: Defined . . . 20
16.1.4 Level 4: Managed . . . 20
16.1.5 Level 5: Optimised . . . 21
16.2 Assessment Dimensions . . . 21

17 Practical Templates **21**
17.1 Suggested Appendices . . . 21

18 Customisation Notes **21**

19 References **22**

1 Executive Summary

ISO/IEC 27001 provides the requirements for establishing, implementing, maintaining, and continually improving an information security management system (ISMS). It enables organisations to manage information security risks systematically and to demonstrate that information security is governed through a structured management system.

This document provides a practical template for defining the organisation's ISO/IEC 27001 governance model, ISMS scope, risk management approach, control structure, implementation roadmap, and assurance model. It can be used to document how the organisation aligns information security governance, risk treatment, controls, and continual improvement into a coherent operating model.

2 Overview

2.1 Purpose

This document provides a practical template for defining, implementing, operating, and assuring an information security management system aligned to ISO/IEC 27001.

2.2 Objectives

The main objectives of applying ISO/IEC 27001 are to:

- establish a formal and auditable information security management system
- protect confidentiality, integrity, and availability of information
- align information security with business objectives and enterprise risk
- apply systematic risk assessment and risk treatment
- define and maintain appropriate information security controls
- provide evidence of governance, monitoring, and continual improvement
- support internal assurance and external certification where required

2.3 Scope

Describe the scope of ISO/IEC 27001 applicability in the organisation.

2.3.1 In scope

- the defined ISMS boundary
- business units, processes, and services within scope
- information assets and supporting technology
- applications, infrastructure, platforms, and cloud services
- people, facilities, and third parties relevant to the ISMS
- security governance, risk treatment, and control monitoring activities
- incident management, resilience, and continual improvement activities within the ISMS scope

2.3.2 Out of scope

Document justified exclusions, if any.

2.4 Intended Audience

- Board and executive leadership
- Chief Information Security Officer
- Chief Information Officer
- Enterprise Risk Management teams
- Security governance, architecture, and operations teams
- IT operations and service management teams
- Business owners and control owners
- Compliance and legal teams
- Internal audit and assurance teams
- PMO / transformation teams

3 Standard Foundation

3.1 Background

ISO/IEC 27001 is the world's best-known standard for information security management systems and specifies the requirements for establishing, implementing, maintaining, and continually improving an ISMS. It is designed to support a risk-based approach that can be scaled to organisations of different sizes and sectors. :contentReferenceoaicite:1

3.2 ISMS Principles

Document how the organisation applies the core principles of the ISMS:

- risk-based thinking
- leadership and accountability
- information protection based on business needs
- systematic control selection
- evidence-based management
- continual improvement
- integration with organisational processes and governance

3.3 Core Components

Describe the core components of the ISO/IEC 27001 model:

- organisational context
- leadership and policy

- planning
- support
- operation
- performance evaluation
- improvement
- information security risk assessment
- information security risk treatment
- Statement of Applicability

3.4 Relationship to ISO/IEC 27002 and Annex A

Describe how the organisation uses:

- ISO/IEC 27001 for management system requirements
- Annex A as the information security controls reference
- ISO/IEC 27002:2022 for guidance on information security controls

ISO states that ISO/IEC 27001 contains the ISMS requirements, while ISO/IEC 27002 provides detailed control guidance. ISO material and SC 27 guidance also explain that Annex A is a normative reference set of controls that must be considered as part of risk treatment and comparison for completeness. :contentReferenceoaicite:2

3.4.1 Example standards table

Standard / Component	Purpose
ISO/IEC 27001	Defines ISMS requirements
Annex A	Reference set of information security controls
ISO/IEC 27002	Guidance on the implementation and management of controls
Statement of Applicability	Documents selected, excluded, and justified controls

4 Governance Model

4.1 Governance Objectives

Define the governance objectives for ISO/IEC 27001 adoption:

- establish executive accountability for information security

- define the ISMS scope and governance boundary
- align security priorities with enterprise strategy and risk appetite
- assign ownership for risk treatment and control performance
- embed information security into operations, change, architecture, and supplier management
- maintain evidence of implementation and operating effectiveness
- support continual improvement through monitoring, review, corrective action, and audit

4.2 Governance Structure

Describe the governance bodies and their responsibilities.

4.2.1 Example governance bodies

- Board / Risk Committee
- Executive Information Security Steering Committee
- Information Security Forum
- Enterprise Risk Committee
- Architecture Review Board
- Change Advisory Board
- Internal Audit

4.3 Three Lines Model

Describe responsibilities across the three lines.

4.3.1 First line

- ownership of business processes, assets, and operational controls
- execution of security controls
- risk treatment implementation
- evidence production and remediation execution

4.3.2 Second line

- information security governance
- policy and standard setting
- risk oversight
- compliance monitoring
- challenge and advisory support

4.3.3 Third line

- internal audit
- independent assurance
- control effectiveness review

5 Roles and Responsibilities

5.1 Key Roles

Document the main ISO/IEC 27001-related roles.

- Board
- CEO / Executive Management
- Chief Information Security Officer
- Chief Information Officer
- Chief Risk Officer
- Business Service Owner
- Information Asset Owner
- Security Governance Lead
- Security Architect
- Security Operations Lead
- IT Operations Lead
- Risk Manager
- Supplier / Third-Party Risk Manager
- Internal Audit

5.2 RACI Matrix

Use the following model and adapt it.

Activity	Board	Exec	CISO	CIO	Risk	Business Owner	Security Ops	Architecture	Audit
Approve ISMS policy and scope	A	R	C	C	C	I	I	I	I

Activity	Board	Exec	CISO	CIO	Risk	Business Owner	Security Ops	Architecture	Audit
Maintain risk assessment methodology	I	A	R	C	C	I	I	I	I
Approve Statement of Applicability	I	A	R	C	C	C	C	C	I
Implement security controls	I	I	A	C	I	C	R	C	I
Conduct internal ISMS review	I	A	R	C	C	C	C	I	I
Manage security incidents	I	A	R	C	C	C	R	I	I
Track corrective actions	I	A	R	C	C	C	C	I	I

Activity	Board	Exec	CISO	CIO	Risk	Business Owner	Security Ops	Architecture	Audit
Perform independent assurance	I	I	I	I	I	I	I	I	R/A

6 Policy Framework

6.1 Core Policies

List and describe the main ISMS-related policies.

- Information Security Policy
- Risk Assessment and Risk Treatment Methodology
- Access Control Policy
- Information Classification and Handling Policy
- Asset Management Standard
- Cryptography Policy
- Logging and Monitoring Standard
- Vulnerability Management Standard
- Incident Management Policy
- Business Continuity / Disaster Recovery Policy
- Supplier Security Policy
- Secure Development Policy
- Human Resources Security Policy

6.2 Standards and Procedures

Document the standards, procedures, control baselines, and operational guidance supporting the ISMS.

7 Core Processes

7.1 Context and Scope Management

Describe how the organisation determines and maintains:

- internal and external issues
- interested parties and their requirements
- the ISMS scope statement
- interfaces and dependencies
- applicability boundaries

7.2 Risk Assessment

Describe the process for:

- defining risk criteria
- identifying information security risks
- assessing likelihood and impact
- evaluating risks against criteria
- prioritising treatment actions
- documenting results

7.3 Risk Treatment

Describe the process for:

- selecting treatment options
- determining necessary controls
- comparing selected controls with Annex A
- documenting inclusions and exclusions
- assigning owners and due dates
- approving residual risk
- tracking treatment implementation

7.4 Statement of Applicability

Document how the organisation maintains the Statement of Applicability, including:

- selected controls
- excluded controls

- reasons for inclusion or exclusion
- implementation status
- associated policies or procedures
- accountable owners

7.5 Operational Control Management

Describe the processes for:

- access management
- change control
- vulnerability management
- logging and monitoring
- supplier oversight
- backup and recovery
- incident handling
- exception management

7.6 Incident Management

Describe the lifecycle for:

- event detection
- triage
- escalation
- containment
- eradication
- recovery
- evidence handling
- lessons learned
- corrective action tracking

7.7 Performance Evaluation and Improvement

Describe the process for:

- monitoring and measurement
- internal audit
- management review
- nonconformity handling
- corrective action
- continual improvement

8 Control Framework

8.1 Control Domains

Organise the control environment using the Annex A themes.

8.1.1 Example control domains

- organisational controls
- people controls
- physical controls
- technological controls
- governance and oversight
- risk management
- operational security
- supplier security
- incident management
- resilience and recovery
- monitoring and assurance
- continual improvement

8.2 Sample Control Catalogue

Control ID	Control Name	Objective	Control Owner	Frequency	Evidence
ISO-01	ISMS policy approved	Ensure formal leadership direction	CISO	Annual	Approved policy
ISO-02	Risk assessment performed	Identify and evaluate security risks	Risk Manager	Annual / change-driven	Risk assessment records
ISO-03	Statement of Applicability maintained	Document selected and excluded controls	Security Governance Lead	Annual / change-driven	SoA

Control ID	Control Name	Objective	Control Owner	Frequency	Evidence
ISO-04	Internal audit completed	Validate ISMS conformance and effectiveness	Audit Lead	Annual	Audit reports
ISO-05	Management review performed	Ensure leadership oversight and decisions	Executive Sponsor	Annual	Management review minutes
ISO-06	Corrective actions tracked	Improve non-conformity resolution	ISMS Manager	Ongoing	Action tracker

9 Artefacts and Evidence

9.1 Required Artefacts

Document the key ISO/IEC 27001 artefacts.

- ISMS scope statement
- information security policy
- risk assessment methodology
- risk treatment methodology
- risk register
- risk treatment plan
- Statement of Applicability
- asset inventory
- control standards and procedures
- supplier security assessments
- vulnerability and patch records
- access review records
- incident register
- internal audit plan
- internal audit reports
- management review outputs
- corrective action register
- competency and awareness records
- metrics and dashboard packs
- certification audit materials where applicable

9.2 Evidence Model

For each artefact define:

- owner
- purpose
- location
- frequency of update
- retention period
- assurance mechanism

10 Architecture and Technology Implications

10.1 Security by Design

Describe how ISMS requirements are embedded into:

- enterprise architecture
- solution design
- cloud architecture
- network and infrastructure design
- identity and access management
- data protection architecture
- software delivery pipelines
- supplier integration patterns
- operational monitoring design

10.2 Technology Landscape View

Document the security-relevant technology landscape:

- business services and critical processes
- application and data estate
- infrastructure and cloud services
- identity and access ecosystem
- security tooling landscape
- logging and monitoring architecture
- backup and recovery architecture
- third-party technology dependencies

10.3 Asset and Dependency Mapping

Include or reference:

- asset inventories
- application dependency diagrams
- network and trust zone diagrams
- data flow diagrams
- supplier dependency maps
- resilience and recovery dependency maps

11 Risk Management

11.1 Information Security Risk Model

Describe how information security risks are identified, assessed, treated, accepted, escalated, and monitored within the ISMS.

11.2 Example Risk Categories

- unclear ISMS scope or governance
- incomplete asset visibility
- weak identity and access management
- poor control implementation
- insecure change and development practices
- inadequate monitoring and logging
- supplier security exposure
- insufficient incident response capability
- weak recovery arrangements
- poor evidence and assurance discipline

11.3 Risk Register Template

Risk ID	Risk Description	Cause	Impact	Likelihood	Inherent Risk	Control Strength	Residual Risk	Owner
IS-01	Example	Example	Example	Medium	High	Medium	Medium	Example

12 Metrics and Reporting

12.1 Key Metrics

Examples of ISMS metrics:

- percentage of assets classified
- percentage of risks assessed on schedule
- percentage of treatment actions completed on time
- percentage of controls implemented as planned
- number of significant incidents
- vulnerability remediation performance
- access review completion rate
- supplier assessment coverage
- number of audit findings open vs closed
- percentage of corrective actions closed on time
- percentage of management review actions completed
- percentage of ISMS objectives achieved

12.2 Dashboard Structure

Suggested dashboard views:

- executive information security dashboard
- ISMS performance dashboard
- risk and treatment dashboard
- incident and vulnerability dashboard
- supplier security dashboard
- audit and corrective action dashboard

13 Audit and Assurance

13.1 Assurance Model

Document the assurance approach across:

- management self-assessment
- control owner attestations
- second-line compliance reviews
- internal audit
- certification audit support where applicable

- corrective action verification

13.2 Testing Themes

- scope and governance effectiveness
- risk assessment and treatment quality
- Statement of Applicability quality
- control implementation and operating effectiveness
- incident handling
- supplier control coverage
- management review effectiveness
- corrective action discipline
- evidence completeness and traceability

14 Implementation Roadmap

14.1 Maturity Phases

14.1.1 Phase 1: Foundation

- define organisational context and ISMS scope
- establish governance and executive sponsorship
- approve core policy framework
- define risk assessment and treatment methods
- build initial asset inventory and baseline controls

14.1.2 Phase 2: Control Design

- perform risk assessment
- create risk treatment plan
- develop Statement of Applicability
- implement priority control improvements
- establish incident, supplier, and monitoring processes

14.1.3 Phase 3: Integration

- embed ISMS into change, architecture, procurement, and operations
- improve evidence collection and monitoring
- establish internal audit and management review cycle
- align corrective action tracking with enterprise governance

14.1.4 Phase 4: Optimisation

- refine metrics and dashboards
- strengthen automation and control monitoring
- improve management review quality
- enhance assurance readiness and continual improvement
- support certification maintenance where applicable

14.2 Roadmap Table

Initiative	Description	Owner	Priority	Timeline	Dependency	Status
Example	Example	Example	High	Q1-Q2	Example	Planned

15 Cross-Framework Integration

15.1 Relationship to Other Frameworks

Describe how ISO/IEC 27001 integrates with:

- NIST Cybersecurity Framework
- NIS2
- DORA
- GDPR
- AI Act
- COBIT
- ITIL
- TOGAF
- enterprise risk management
- business continuity and operational resilience frameworks

15.2 Example Mapping Themes

ISO/IEC 27001 Theme	Related Framework	Integration Point
ISMS governance	COBIT	Governance objectives and accountability
Risk treatment	NIST CSF	Cyber risk management and capability improvement
Incident management	NIS2 / DORA	Cyber incident governance and reporting
Security architecture	TOGAF	Architecture governance and security viewpoints
Privacy-related controls	GDPR	Data protection and processing safeguards

16 Maturity Model

16.1 Suggested Maturity Levels

16.1.1 Level 1: Initial

Security activities are reactive, fragmented, and poorly governed.

16.1.2 Level 2: Repeatable

Basic ISMS components exist but are inconsistently applied and weakly evidenced.

16.1.3 Level 3: Defined

The ISMS scope, policies, risk treatment, and controls are documented and broadly implemented.

16.1.4 Level 4: Managed

The ISMS is measured, reviewed, audited, and actively improved through leadership oversight.

16.1.5 Level 5: Optimised

Information security is fully integrated into enterprise governance, architecture, operations, and supplier management with strong evidence and continual improvement.

16.2 Assessment Dimensions

- governance
- scope and context management
- risk assessment
- risk treatment
- control implementation
- incident management
- supplier security
- metrics and reporting
- audit and management review
- continual improvement

17 Practical Templates

17.1 Suggested Appendices

- Appendix A: ISMS scope statement template
- Appendix B: Risk assessment template
- Appendix C: Risk treatment plan template
- Appendix D: Statement of Applicability template
- Appendix E: Information security control catalogue
- Appendix F: Internal audit checklist
- Appendix G: Management review agenda template
- Appendix H: ISO/IEC 27001 RACI matrix

18 Customisation Notes

This template should be tailored to reflect:

- organisational structure
- business and regulatory context
- ISMS scope boundary
- critical services and information assets

- sourcing and third-party model
- cloud and technology estate
- maturity level
- assurance and certification expectations
- operating model and budget constraints

19 References

Add authoritative references here, for example:

- ISO/IEC 27001:2022
- ISO/IEC 27001:2022/Amd 1:2024
- ISO/IEC 27002:2022
- ISO/IEC 27000 family guidance
- internal information security policies and standards
- enterprise risk framework
- architecture and resilience standards